

针对某专用密码协议的形式化分析及攻击路径研究实例

检测室 张庆晟、谢亚丽、陈子建、刘峻垚

一、引言

密码协议作为网络通信安全的核心，其设计的正确性直接决定身份认证、密钥协商、数据传输等安全机制的有效性，在各类分析验证方法中，形式化分析方法¹已被证明是最有效的手段。密码协议的形式化分析是指利用形式化语言对密码协议安全属性进行严格刻画和准确建模，然后应用数学方法证明该模型是否满足相应的安全属性²。

本文在针对某专用密码协议的安全性分析过程中，依托密码协议形式化分析工具，基于 Dolev-Yao 攻击者模型³开展形式化分析工作，通过使用密码协议形式化操作语义，对形式化分析过程中安全协议建模、安全属性定义、敌手模型和攻击路径解读等重难点问题进行深度剖析，形成具有针对性的攻击路径，旨在挖掘某专用密码协议的潜在安全问题并给出切实有效的协议设计防护措施。

二、密码协议形式化操作语义

密码协议形式化分析的有效性建立在严格且可计算的操作语义基础上，通常涵盖协议建模、事件描述、分析验证三大部分，编写协议建模和事件描述的形式化代码需要使用一套特定的操作语义。密码协议形式化分析为操作语义的描述规定了一套协议规范，其中定义了代理之间消息术语的交换。

1 高尚,胡爱群,石乐,陈先棒.安全协议形式化分析研究[A].密码学报,2014,1(5): 504-512.

2 赵辉.安全协议形式化分析技术的研究[J].软件学报.2010,32(09):2849-2866.

3 冯登国,范红.安全协议形式化分析理论与方法研究综述[J].中国科学院研究生院学报,2003,20(4):389-406.

$$\begin{aligned} \mathcal{E} = \{ & send\ell(r, r', t), read\ell(r', r, t), claim\ell(r, c[, t]) | \ell \in \mathcal{I}, r, r' \in \mathcal{R}, t \\ & \in RoleTerm, c \in Claim \} \end{aligned}$$

例如,角色规范会被定义为一组初始知识和事件列表,如上所示:

密码协议形式化分析的主要实体类别如表 1⁴所示,同时也列举了组成这些集合的一些典型元素,这些都是构成密码协议分析代码的必要内容。

表 1 密码协议形式化操作语义定义表

类别 Description	符号 Set	典型元素 TypicalElements	说明
Variables (变量)	$\mathcal{V}$	V, W, X, Y, Z	动态可变的元素, 如需传输、计算或更新的中间数据、临时参数等
Constants (常量)	$\mathcal{C}$	$ni, nr, sessionkey$	固定不变的元素, 多为预设的关键静态信息, 如身份标识 (ni/nr)、会话密钥 (sessionkey)
Roles (角色)	$\mathcal{R}$	i, r, s	参与实体的身份, 代表不同参与方的功能属性, 如 i (发起方)、r (接收方) 等
Functions (函数)	$\mathcal{F}$	$Sk(), pk(), \sim, k, hash()$	实现特定逻辑的操作单元, 用于完成加密、密钥处理等, 如 sk (私钥生成)、pk (公钥生成)、k (密钥派生)、hash (哈希) 等
Trustedagents (可信代理)	$\mathcal{AT}$	a, b, c	具备安全性和权威性的实体, 可承担关键信任相关任务, 如密钥分发、身份认证等, 行为被默认可信
Untrustedagents (不可信代理)	$\mathcal{AU}$	e	存在安全风险的实体, 可能是潜在攻击者或不可靠参与方, 协议设计需防范其恶意行为 (如数据篡改、伪造)

三、某专用密码协议形式化分析实例

4 Cas Cremers.Sjouke Mauw.Operational Semantics and Verification of Security Protocols[D]电子工业出版社,2018:11.

本文以某专用密码协议为分析对象,通过形式化建模、断言验证、攻击路径构建等方式,深入分析了该协议的潜在问题。

(一) 协议流程简介

本文依托密码协议形式化分析工具,以某专用密码协议为例进行分析,该协议主要实现某系统和某密码机之间管控指令的安全传输,协议流程如图 1 所示:

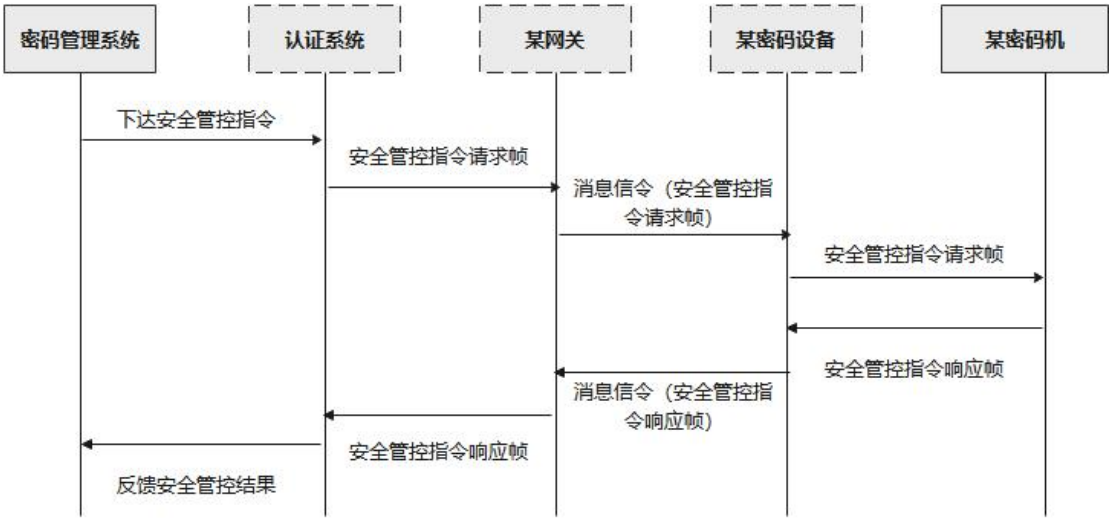


图 1 某专用密码协议消息流程图

(二) 形式化建模

将密码协议流程或流程图转化为形式化语言是协议分析的首要难题。在形式化建模过程中,首先需要明确协议实体,然后基于角色、新鲜值和变量等内容分别构建角色项,其中变量用于存储接收到的消息参数,新鲜值是角色实例化后新生成的随机数,角色则为预定义参与协议交互过程的双方身份⁵。

在该协议形式化建模过程中,首先需要进行宏定义,使用 hashfunction h 声明一个哈希函数,定义宏 macro

5 陈琼,缪祥华,袁梅宇.OpenID Connect 协议的形式化分析与优化[J/OL].计算机技术与发展.
<https://doi.org/10.20165/j.cnki.ISSN1673-629X.2025.0207>.

$k=\{randomB\}randomA,\{randomA\}randomB$ ，确认通信角色分别为某密码机（UE）和某系统（CKMG），然后定义协议名称为 protocol CryptographyManagement(UE,CKMG)，并基于角色和变量等分别构建角色项 role UE {} 和 role CKMG {}。

协议对实体数据的操作可划分为发送消息、数据处理和接收消息三个部分。在角色 UE 中，使用 fresh 声明一个 Nonce 类型的新鲜值 randomA，并将其作为 send()函数的参数，用角色 CKMG 公钥加密 $\{randomA\}pk(CKMG)$ 、角色 UE 私钥签名 $\{h(randomA)\}sk(UE)$ 后发送给角色 CKMG，从而完成发送事件 send_1 的定义；然后相应对接收事件进行定义，使用 var 存储接收的值并将其作为 recv()函数的参数，最后通过对其他发送事件和接收事件的定义，明确协议中的消息传递过程，进一步构建完整的协议模型。

```

hashfunction h;
macro k={randomB}randomA,{randomA}randomB;

protocol CryptographyManagement(UE,CKMG){
  role UE{

    fresh randomA,request:Nonce;
    var randomB,responsedata:Nonce;

    send_1(UE,CKMG,{randomA}pk(CKMG),{h(randomA)}sk(UE));
    recv_2(CKMG,UE,{randomA,randomB,CKMG}pk(UE),{h(randomA,randomB)}sk(CKMG));
    send_3(UE,CKMG,{request}k,h({request}k));
    recv_4(CKMG,UE,{responsedata}k,h({responsedata}k)); }
}

```

密码协议形式化分析的核心是验证协议是否满足相关安全属性，通过验证安全属性，可以确保协议在敌手攻击环境下仍能够保持其安全特性。表 2³ 中的两个断言分别从会话密钥机密性和实体非单射消息一致性角度描述了协议的安全属性，其中断言一尝试论证在长期密

钥未被泄露的情况下，其协商产生的会话密钥就绝不会被攻击者获取；断言二尝试论证只要客户端长期密钥未被泄露，那么客户端持有的每一个会话密钥都必然经过服务端明确认证，这确保了客户端只会接受由合法服务端建立的会话密钥，即前者确保了通信内容无法被窃听，后者确保了通信对象身份真实可信。

表 2 密码协议形式化分析安全属性定义表

断言一（机密性）	断言二（非单射消息一致性）
$lemma\ session_key_secrecy:$ $\forall t \in traces(P): \forall ((\theta, \rho, \sigma), \gamma) \in t:$ $honest((\theta, \rho, \sigma)) \Rightarrow AKN(t) \not\models \{\theta, \rho,$ $\sigma\}(r(t))$	$lemma\ niagree:$ $\forall t \in traces(P) \exists \Gamma \in Cast(P, t):$ $\forall inst: (inst, \gamma) \in t \wedge honest(inst) \Rightarrow$ $\forall \zeta, \varrho \in RoleEvent: \zeta \rightarrow \varrho \wedge \varrho \prec_p \gamma \Rightarrow$ $\exists inst'', inst': (inst'', \zeta) <_t (inst', \varrho) <_t (inst, \gamma) \wedge$ $runidof(inst'') = \Gamma((inst, \gamma), role(s)) \wedge$ $runidof(inst') = \Gamma((inst, \gamma), role(\varrho)) \wedge$ $cont((inst'', \zeta)) = cont((inst', \varrho))$

本文采用的密码协议形式化分析工具内置了包含上述断言的安全断言事件，如 SKR、Alive、Weakagree、Niagree、Nisynch 等，上述两个断言使用 claim 定义安全断言事件如下所示：

$$claim(UE, SKR, randomA);$$

$$claim(CKMG, SKR, randomA);$$

$$claim(CKMG, Niagree);$$

$$claim(UE, Niagree);$$

（三）结果验证

使用密码协议形式化分析工具，基于 Dolev-Yao 攻击者模型，对某专用密码协议定义的多种安全属性分别进行了验证，验证结果如图 2 所示。从验证结果图中可以看出，角色 UE 的非单射消息一致性（Niagree）和非单射同步一致性（Nisynch）两个安全属性均验证失败，分别存在 2 种不同的攻击路径。基于上述验证结果，进一步推断，此协议运行过程中，很有可能攻击者介入到通信双方之间，通过拦截、

篡改或伪造消息窃取敏感信息破坏了双方正常通信，下文将根据验证结果进一步分析协议可能存在的安全漏洞。

Claim				Status	Comments	Patterns
CryptographyManagement	UE	CryptographyManagement,UE1	SKR request	Ok	Verified	No attacks.
		CryptographyManagement,UE2	SKR responsedata	Ok	Verified	No attacks.
		CryptographyManagement,UE3	Alive	Ok	Verified	No attacks.
		CryptographyManagement,UE4	Weakagree	Ok	Verified	No attacks.
		CryptographyManagement,UE5	Niagree	Fail	Falsified	Exactly 2 attacks. 2 attacks
		CryptographyManagement,UE6	Nisynch	Fail	Falsified	Exactly 2 attacks. 2 attacks
CKMG		CryptographyManagement,CKMG1	SKR request	Ok	Verified	No attacks.
		CryptographyManagement,CKMG2	SKR responsedata	Ok	Verified	No attacks.
		CryptographyManagement,CKMG3	Alive	Ok	Verified	No attacks.
		CryptographyManagement,CKMG4	Weakagree	Ok	Verified	No attacks.
		CryptographyManagement,CKMG5	Niagree	Ok	Verified	No attacks.
		CryptographyManagement,CKMG6	Nisynch	Ok	Verified	No attacks.

Done.

图 2 某专用密码协议结果验证图

(四) 攻击路径

1.针对非单射消息一致性⁶的攻击路径

在某专用密码协议验证结果中，针对非单射消息一致性有两种不同方式的攻击路径，下文以其中一种攻击路径为例进行介绍，该攻击路径中包含运行实例 Run #1 和 Run #2。在运行实例 Run #1 中，Bob 作为 UE 角色，Alice 作为 CKMG 角色，首先 Bob 生成随机数 randomA#1 和请求消息 request#1，使用 Alice 公钥加密 {randomA#1}pk(Alice)，Bob 私钥签名 {h(randomA#1)}sk(Bob)后通过 send_1 消息发送给 Alice。在运行实例 Run#2 中，Alice 接收到来自 Bob 的消息后，生成随机数 randomB#2 和响应消息 responsedata#2，然后使用 Bob 公钥加密 {randomA#1,randomB#2,Alice}pk(Bob)，Alice

6 刘家芬.安全协议形式化分析中认证测试方法的研究.[博士学位论文].四川:电子科技大学,2009.

私钥签名 $\{h(\text{randomA\#1}, \text{randomB\#2})\}sk(\text{Alice})$ 后，通过 send_2 消息发送给 Bob。Bob 收到消息后，通过 send_3 消息给 Alice 发送响应消息，但此时攻击者一方面利用初始敌手知识中的哈希函数 h 计算消息哈希值，另一方面通过伪造 Alice 身份，篡改该消息并利用重定向机制将消息重定向给 Bob 自己，让 Bob 以为正与 Alice 通信，所以在 recv_4 中 Bob 错误地接收到本应由 Alice 处理的消息，导致 Bob 和 Alice 协议运行状态不一致，即发送者发送和接收的消息与接收者接收和发送的消息内容不一致，这一过程违反了协议的非单射消息一致性（Niagree）声明，某专用密码协议非单射消息一致性攻击路径 1 如图 3 所示：

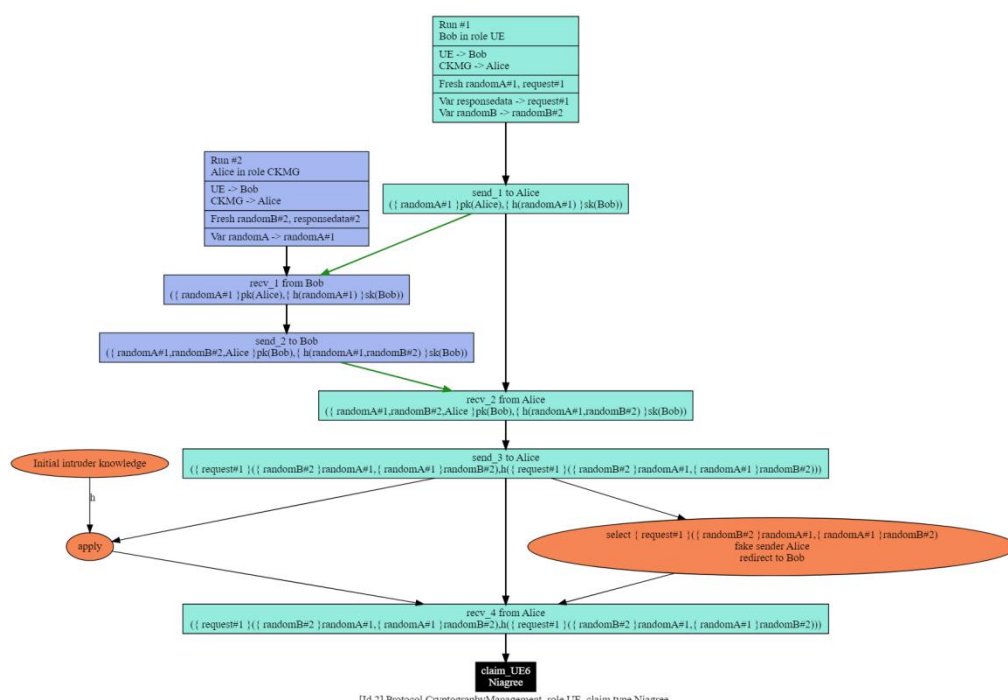


图 3 某专用密码协议非单射消息一致性攻击路径 1

某专用密码协议非单射消息一致性攻击路径 2 如图 4 所示：

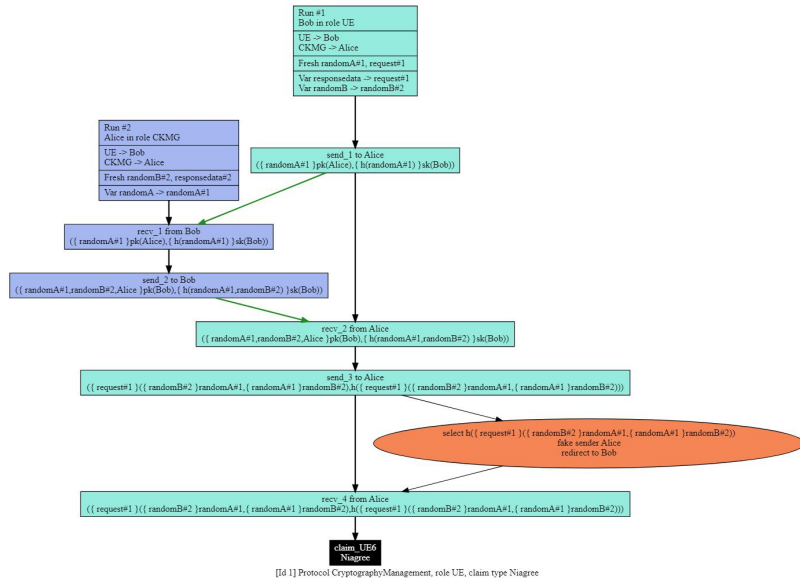


图 4 某专用密码协议非单射消息一致性攻击路径 2

2. 针对非单射同步一致性⁶的攻击路径

类似地，攻击者以同样的攻击路径，导致发送事件和接收事件的先后次序不一致，这一过程违反了协议的非单射同步一致性（Nisynch）声明，某专用密码协议非单射同步一致性攻击路径 1 如图 5 所示：

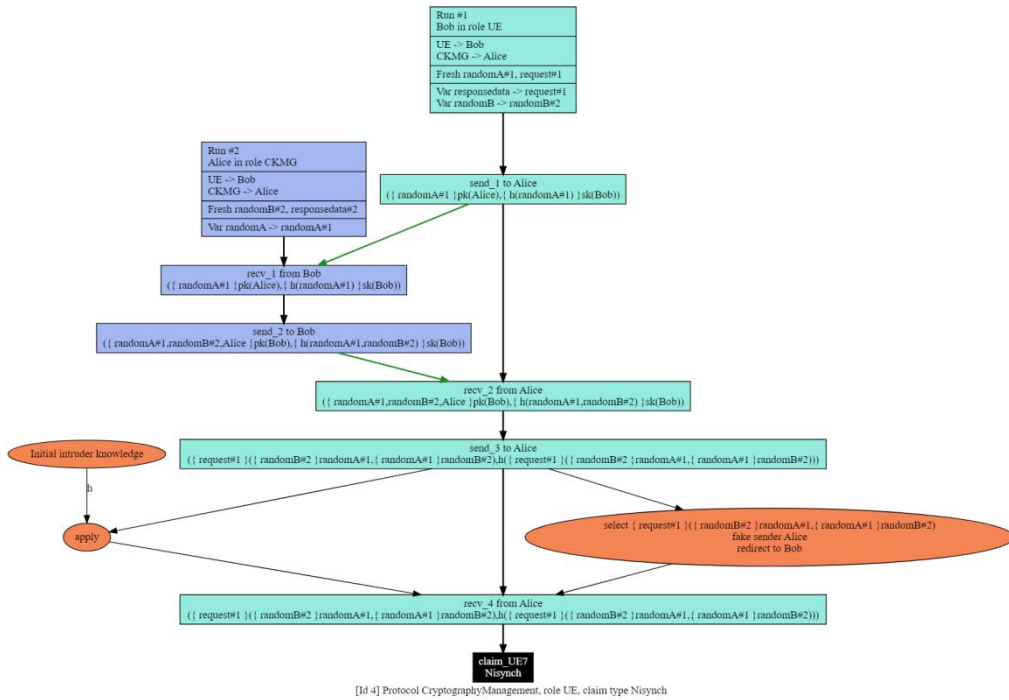


图 5 某专用密码协议非单射同步一致性攻击路径 1

某专用密码协议非单射同步一致性攻击路径 2 如图 6 所示：

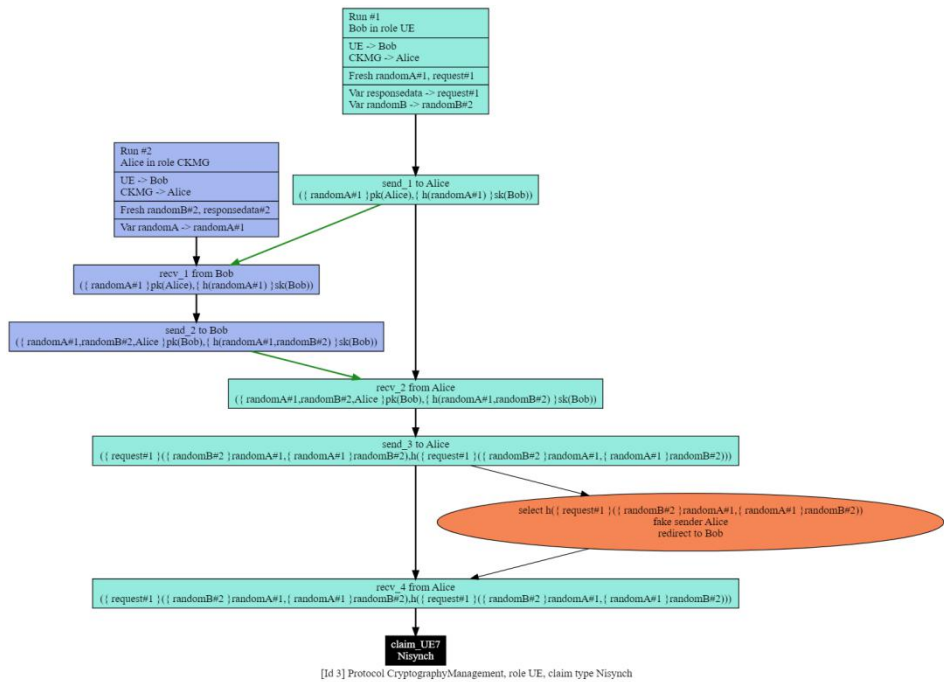


图 6 某专用密码协议非单射同步一致性攻击路径 2

四、密码协议设计建议

本文基于形式化分析实践以及对密码协议安全属性的理解，提出以下五项普适性的密码协议设计建议，这些建议旨在从设计源头规避常见安全漏洞，提升协议在复杂对抗环境下的鲁棒性。

（一）明确安全目标与敌手模型

在密码协议设计之初，必须清晰定义协议所需满足的安全属性，并明确可抵抗的敌手能力模型。形式化分析工具也应在设计早期阶段介入，将安全属性转化为可验证的断言，避免安全需求模糊导致根本性设计缺陷。

（二）保障消息新鲜性与身份绑定

密码协议必须能够有效区分新旧消息以防止重放攻击，需要引入并严格验证新鲜值、时间戳或序列号。同时，关键信息必须与通信方

身份进行强绑定，以确保消息来源的真实性和不可否认性，从根本上抵御中间人攻击和身份冒充。

（三）实施最小特权与纵深防御原则

密码协议每个角色应仅被授予完成其功能所必需的最小知识和权限。临时生成的会话密钥等在使用后应及时销毁，同时，应采用纵深防御策略，结合加密与认证、在密钥协商后使用协商密钥进行二次确认等，使得即使某一机制被攻破，协议整体仍能保持安全。

（四）强化密钥生命周期管理与前向安全

密钥是密码协议安全的核心，设计时需系统规划密钥的生成、存储、使用、更新和销毁等全生命周期管理。如会话密钥应定期更新并确保密钥的泄露不会危及历史会话的安全，即实现前向安全性。

（五）构建简洁清晰的状态机与原子操作

密码协议逻辑应尽可能简洁，角色内部的状态转换必须清晰。复杂协议的交互逻辑极易引入状态同步问题，导致攻击者有机可乘。每个协议回合应设计为原子操作，要么成功完成并进入下一状态，要么失败并安全回滚，从而有效防止类型混淆攻击和状态机泄露。

五、总结

本文在传统密码协议分析方法的基础上，采用了基于定理证明和模型检测⁷的形式化分析方法，通过形式化分析精准识别了某专用密码协议非单射消息一致性、非单射同步一致性等安全属性漏洞，解决了该类漏洞在逻辑建模与攻击路径分析上的难点，并通过实际案例验证了形式化分析方法的有效性，为某系统防护能力提供了有力支撑，也为某专用密码协议的完善工作提供了科学依据和理论基础。

⁷薛锐,冯登国.安全协议的形式化分析技术与方法[J].计算机学报,2006,29(1):1-20.

基于形式化分析方法在协议检测方面的独特优势，中心亟需加强建设密码协议分析能力并构建系统性形式化分析体系，后续研究也将逐步拓展至抗量子密码协议分析，并融合 AI 分析能力以发现深层次安全漏洞，为密码协议检测工作提供新范式。

参考文献

- [1] 高尚,胡爱群,石乐,陈先棒.安全协议形式化分析研究[A].密码学报,2014,1(5): 504–512.
- [2] 赵辉.安全协议形式化分析技术的研究[J].软件学报.2010,32(09):2849-2866.
- [3] 冯登国,范红.安全协议形式化分析理论与方法研究综述[J].中国科学院研究生院学报,2003,20(4):389-406.
- [4] Cas Cremers.Sjouke Mauw.Operational Semantics and Verification of Security Protocols[D]电子工业出版社,2018:11.
- [5] 陈琼,缪祥华,袁梅宇.OpenID Connect 协议的形式化分析与优化[J/OL].计算机技术与发展.
<https://doi.org/10.20165/j.cnki.ISSN1673-629X.2025.0207>.
- [6] 刘家芬.安全协议形式化分析中认证测试方法的研究.[博士学位论文].四川:电子科技大学,2009.
- [7] 薛锐,冯登国.安全协议的形式化分析技术与方法[J].计算机学报,2006,29(1):1-20.